University of Coimbra
Department of Informatics Engineering

Secure Software: Intermediate Project Report

Document Management Platform Hardening

Authors:
Tiago Costa (uc2025195689)
Fábio Godinho (uc2025186895)
João Lino (uc2025246120)
Miguel Brazão (uc2025188018)

Secure Software (MEI)
Academic Year 2025-2026

Coimbra, April 3, 2026

Contents

1 Introduction and System Scope **2**
1.1 Stakeholders . . . 2
1.2 Assets to Protect . . . 2

2 Security Requirements Engineering (SQUARE) **2**
2.1 Security Goals . . . 3
2.2 Risk Assessment Summary . . . 3
2.3 Threat Modeling and Attack Surface . . . 4
2.4 Detailed Misuse Case Analysis and Attack Trees . . . 4
2.5 Elicited Security Requirements . . . 7
2.6 Categorization and Prioritization . . . 8

3 Secure Architecture and Design **10**
3.1 Security Domains and Trust Boundaries . . . 10
3.2 Security Enforcement Points (SEP) . . . 11
3.3 Architectural Security Principles . . . 12

4 Traceability Matrix **13**

A Detailed Misuse Cases and Attack Trees **16**
A.1 Misuse Case 01: Unauthorized Logon . . . 17
A.2 Misuse Case 02: Denial-of-Service . . . 18
A.3 Misuse Case 03: HTTPS Manipulation . . . 19
A.4 Misuse Case 04: Man-in-the-Middle . . . 20
A.5 Misuse Case 05: SQL Injection . . . 21
A.6 Misuse Case 06: Information Leakage . . . 22
A.7 Misuse Case 07: Unauthorized Document Access . . . 23
A.8 Misuse Case 08: Malware Injection . . . 24

1 Introduction and System Scope

The target system for this project is a web-based document management platform designed to allow users to securely upload, store, manage, and share digital documents. Given that the uploaded documents may contain sensitive, proprietary, or private information, the system requires rigorous security controls. The scope of this intermediate report encompasses the security requirements engineering and the secure architectural design necessary to harden the baseline application against identified threats.

1.1 Stakeholders

To ensure proper access control and threat modeling, the following key stakeholders have been identified based on their interaction with the system:

- **Users:** Individuals who authenticate to the platform to upload, download, manage, and share their privately owned documents.
- **Reviewers:** Specialized users who are granted explicit access to specific documents shared with them by owners for review or processing purposes.
- **Administrators:** Highly privileged personnel responsible for overseeing system operations, managing the platform, and controlling user account states (e.g., enabling or disabling accounts).

1.2 Assets to Protect

A critical step in the SQUARE methodology is identifying the assets that require protection. For this platform, the primary assets are:

- **Digital Documents (Core Asset):** The physical files uploaded by users residing in the document storage, which are the primary target for confidentiality breaches.
- **User Metadata and Authorization Data:** Database records containing user identities, role assignments, document ownership mapping, and sharing permissions.
- **Authentication Data:** Sensitive credentials, passwords, and active session tokens required to verify user identities and prevent spoofing.
- **System Infrastructure and Availability:** The underlying Application Server, PostgreSQL database, and Document Storage, which must remain available and responsive to ensure continuous operational processes and academic deadlines.

2 Security Requirements Engineering (SQUARE)

We utilize the SQUARE methodology to systematically derive security requirements based on the identified assets and stakeholders.

2.1 Security Goals

- **SG.1 (Authentication & Access Control):** Robust authentication and authorization mechanisms must be implemented to prevent unauthorized access.
- **SG.2 (Privacy & Compliance):** Ensure compliance with privacy regulations (e.g., GDPR/CCPA) regarding the handling of sensitive user data.
- **SG.3 (Availability):** Ensure that platform services and documents remain accessible to authorized users whenever needed, especially during critical academic periods.
- **SG.4 (Confidentiality & Integrity):** Protect sensitive information (e.g., via encryption) to mitigate data leaks and prevent unauthorized tampering.

2.2 Risk Assessment Summary

Following SQUARE Step 4, risks are prioritized based on the estimated likelihood and impact of the eight identified misuse cases.

ID	Threat / Misuse Case	Likelihood	Impact	Risk Level
MC-05	SQL Injection (SQLi)	High	High	**Critical**
MC-03	HTTPS Manipulation (IDOR)	High	High	**Critical**
MC-01	Unauthorized Logon (Spoofing)	Medium	High	**High**
MC-07	Unauthorized Document Access	Medium	High	**High**
MC-08	Malware Injection via Upload	Medium	High	**High**
MC-06	Information Leakage (Storage/DB)	Medium	Medium	**Medium**
MC-02	Denial of Service (DoS)	Low	High	**Medium**
MC-04	Man-in-the-Middle (MitM)	Low	High	**Medium**

Table 1: Risk Assessment Table mapping identified Misuse Cases to Risk Levels.

2.3 Threat Modeling and Attack Surface

The following diagram illustrates the structured threat modeling of the system, identifying potential attack vectors across trust boundaries.

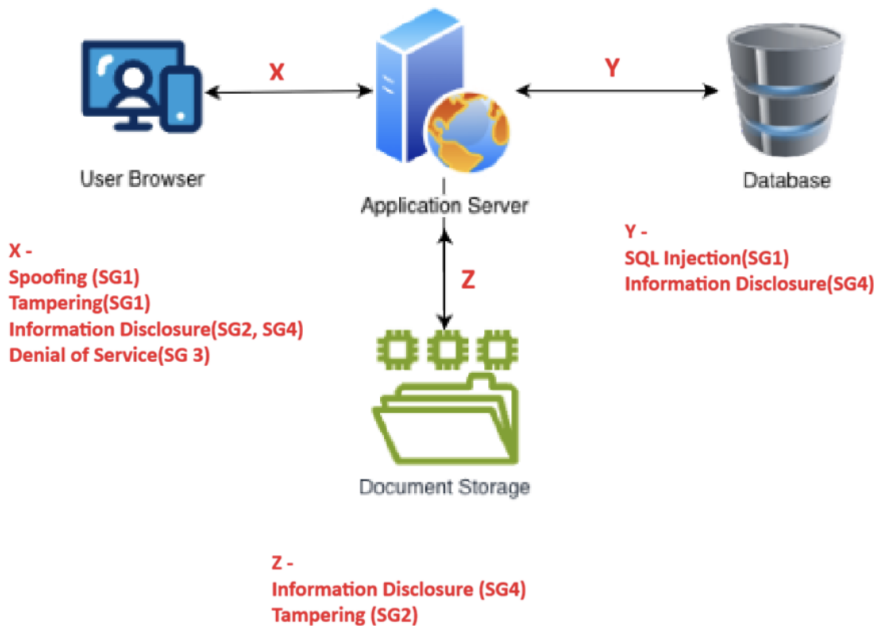

Figure 1: System Threat Modeling Diagram identifying Spoofing (X), Tampering (X, Z), and Injection (Y) points.

2.4 Detailed Misuse Case Analysis and Attack Trees

To maintain the readability and flow of this report, the following tables provide a consolidated executive summary of the primary attack vectors, mis-actors, and worst-case scenarios for each identified threat.

Important Note: The complete, exhaustive misuse case tables detailing pre-conditions, wanted guarantees (Prevention, Detection, Recovery), and specific architectural recommendations as required by the SQUARE methodology are provided in full within **Appendix A** at the end of this document.

The consolidated summaries and their corresponding attack trees are presented below:

Attribute	**MC-01: Unauthorized Logon**	**MC-02: Denial-of-Service**
Name	Unauthorized logon via Spoofing	DoS during critical periods
Scope	User Auth and Access Control	System Availability
Mis-actors	Unauthorized users / External attackers	External / Malicious Users
Entry Point	Application Layer	Network Layer
Worst Case	Full Admin account compromise	Total service loss during deadlines

Table 2: Consolidated Misuse Case Summary (1-2)

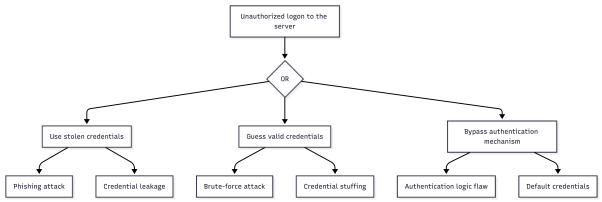

Figure 2: Attack Tree: MC-01

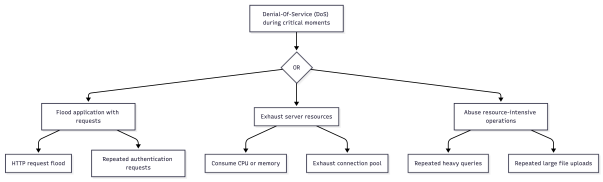

Figure 3: Attack Tree: MC-02

Attribute	MC-03: HTTPS Manipulation	MC-04: Man-in-the-Middle
Name	IDOR Manipulation	MitM via Interception
Scope	Data Privacy and Auth Logic	Data Transit Confidentiality
Mis-actors	Authenticated Malicious Users	Network Eavesdroppers
Entry Point	Application (API Endpoints)	Network
Worst Case	Mass document exfiltration	Theft of Admin session cookies

Table 3: Consolidated Misuse Case Summary (3-4)

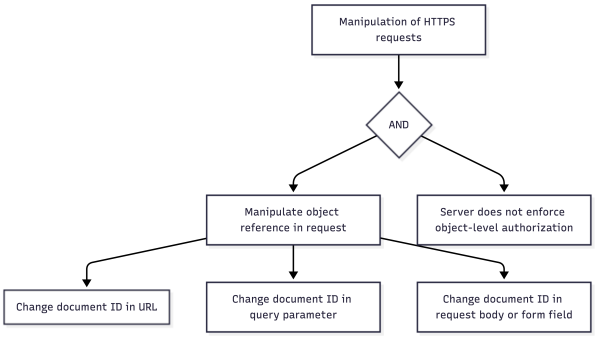

Figure 4: Attack Tree: MC-03

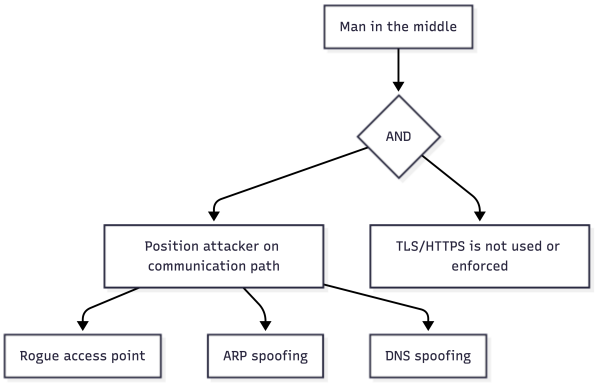

Figure 5: Attack Tree: MC-04

Attribute	MC-05: SQL Injection	MC-06: Information Leakage
Name	SQLi for Elevation of Privilege	Leakage via Insecure Storage
Scope	DB Integrity and Auth Control	Data at Rest Confidentiality
Mis-actors	External / Authenticated Attackers	Malicious Insiders
Entry Point	Application (Input fields)	Database / Network
Worst Case	Total system compromise	Mass user metadata disclosure

Table 4: Consolidated Misuse Case Summary (5-6)

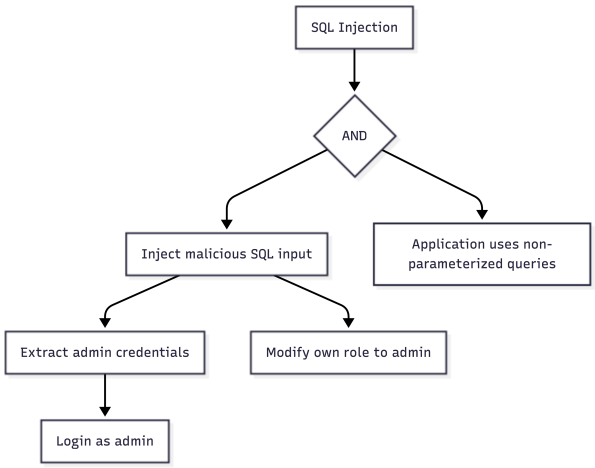

Figure 6: Attack Tree: MC-05

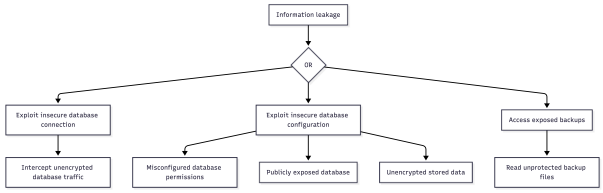

Figure 7: Attack Tree: MC-06

Attribute	MC-07: Unauthorized Document Access	MC-08: Malware Injection
Name	Storage Bypass via Insecure Access	Malware via Document Upload
Scope	Protection of Data at Rest	Software Integrity
Mis-actors	Malicious Insiders / Host Attackers	Authenticated Malicious Users
Entry Point	Storage System	Application (Upload Function)
Worst Case	Direct bypass of App logic	Admin workstation compromise

Table 5: Consolidated Misuse Case Summary (7-8)

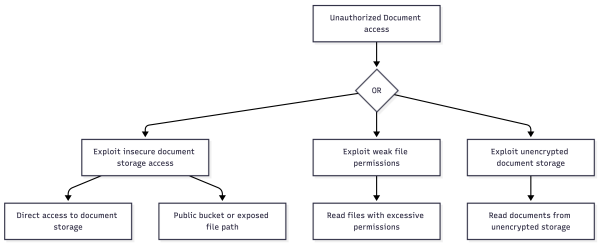

Figure 8: Attack Tree: MC-07

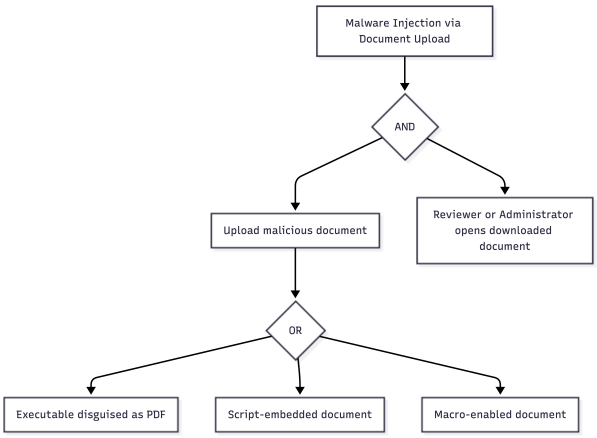

Figure 9: Attack Tree: MC-08

2.5 Elicited Security Requirements

Security requirements must be verifiable, specific, and testable, following SQUARE methodology principles. These requirements are derived directly from the previously defined misuse cases to specify exactly what the system must achieve to mitigate the identified threats.

- **SR.1 (Authentication / Spoofing - MC-01):**
  - The system must require multi-factor authentication for all user access.
  - The system must automatically lock user accounts after 5 consecutive failed login attempts.
- **SR.2 (Availability / DoS - MC-02):**
  - The system must maintain an availability rate of at least 99.5% and handle a minimum of 300 simultaneous connections without service degradation.
  - The system must enforce request rate limits per client to prevent resource exhaustion.
  - The system must continuously monitor and log 100% of network traffic for anomalous patterns.
- **SR.3 (Authorization / IDOR - MC-03):**
  - The system must enforce strict server-side authorization checks to verify resource ownership for every action and access request.
  - The system must ensure that internal object references are obfuscated and not predictably exposed to the client.
  - The system must validate user input and check ownership for every action.
- **SR.4 (Confidentiality in Transit / MitM - MC-04):**
  - The system must encrypt all external communications and actively reject any unencrypted connection attempts.
  - The system must cryptographically validate the identity of all external communicating parties.
  - The system must detect and log suspicious network anomalies (e.g., spoofing attempts).
- **SR.5 (Integrity / SQL Injection - MC-05):**
  - The system must execute database queries in a manner that strictly separates executable code from user-supplied data.
  - The system must strictly validate and sanitize 100% of user-supplied inputs against a predefined allow-list before any processing occurs.
  - The system must restrict database access based on the principle of least privilege.
- **SR.6 (Confidentiality / Information Leakage - MC-06):**

  - The system must identify and classify stored sensitive data according to sensitivity levels.
  - The system must encrypt all sensitive data at rest and ensure it is only accessible to explicitly authorized users.
  - The system must require mutual authentication and encryption for all internal communications between system components.
  - The system must log and monitor 100% of administrative access to sensitive data.

- **SR.7 (Confidentiality / Unauthorized Document Access - MC-07):**
  - The system must enforce strong access controls and the principle of least privilege for all document operations.
  - The system must logically segment the internal network to isolate document storage.
  - The system must generate comprehensive audit logs for 100% of document access events.
  - The system must support regular access reviews and audits.

- **SR.8 (Integrity / Malware Injection - MC-08):**
  - The system must restrict file uploads exclusively to authenticated users and explicitly permitted file formats.
  - The system must proactively scan all uploaded content for malicious payloads.
  - The system must enforce file size and name length limits.
  - The system must ensure that uploaded files cannot be directly executed via web requests.

2.6 Categorization and Prioritization

In accordance with Step 7 of the SQUARE methodology, the elicited security requirements are first categorized by their core security attributes and subsequently prioritized based on the risk levels identified in the risk assessment phase.

Categorization

The requirements are grouped by the primary security goals they address, ensuring comprehensive coverage of the attack surface:

- **Confidentiality (Data Exposure Prevention):** SR.4 (Transit Encryption), SR.6 (Storage Encryption), SR.7 (Document Access Control).
- **Integrity (Tampering Prevention):** SR.3 (IDOR Prevention), SR.5 (SQLi Prevention), SR.8 (Malware Scanning).
- **Availability (Service Continuity):** SR.2 (DoS Mitigation).
- **Authentication & Authorization (Identity & Access):** SR.1 (MFA & Lockout), SR.3 (RBAC Authorization), SR.7 (Least Privilege).

Prioritization

The requirements are prioritized to guide the upcoming implementation and DevSecOps phases. This directly maps to the criticality of the misuse cases they mitigate:

- **High Priority (Mitigating Critical & High Risks):**
  - **SR.3 & SR.5:** Mitigate *Critical* risks (IDOR and SQL Injection) which could lead to mass data exfiltration or total system compromise.
  - **SR.1, SR.7 & SR.8:** Mitigate *High* risks (Spoofing, Unauthorized Storage Access, and Malware Injection) which directly impact core assets and workstation integrity.
- **Medium Priority (Mitigating Medium Risks):**
  - **SR.2, SR.4 & SR.6:** Mitigate *Medium* risks (DoS, MitM, and Metadata Leakage). While essential for Defense in Depth, these rely on infrastructural changes (e.g., mTLS, WAF, rate-limiting) and are prioritized alongside or after the core application logic is secured.

3 Secure Architecture and Design

To ensure that the security requirements defined in Stage 1 are rigorously applied, our architectural design focuses on strategically placing security enforcement points and strictly defining trust relationships between system components.

3.1 Security Domains and Trust Boundaries

Based on the document management system's architecture, three main security domains were identified. These domains are segregated by trust boundaries where data integrity and origin must be strictly validated.

A. Security Domains

- **Public Domain (External/Untrusted):** Comprises the User Browser and the public network (Internet). This environment is outside the organization's control, acting as the residence for external attackers where communications are susceptible to interception.
- **Application Domain (Intermediate Trust):** Comprises the Application Server. This domain processes business logic and access permissions. Although under the organization's control, it interacts directly with the public domain, making it the first point of exposure to attacks.
- **Core Data Domain (High Trust):** Comprises the Database (PostgreSQL) and the Document Storage. This is the most critical domain, as it stores sensitive assets (documents and credentials). Access to this domain must be strictly restricted to the authenticated logic of the application server.

B. Trust Boundaries & Attack Surfaces

- **Boundary: Browser ↔ Application Server (Trust Boundary X):** Separates the external user from the server logic. The attack surface includes HTTP/HTTPS entry points, login forms, and URL parameter fields. This boundary is where threats such as Spoofing (MC-01), Denial-of-Service (MC-02), request manipulation/IDOR (MC-03), and network interception/MitM (MC-04) manifest.
- **Boundary: Application Server ↔ Database (Trust Boundary Y):** The internal communication interface between the application engine and the PostgreSQL database. The attack surface centers on the database connection protocol and the construction of SQL queries. The main associated threats are SQL Injection (MC-05) and Information Leakage if the connection is unencrypted (MC-06).
- **Boundary: Application Server ↔ Document Storage (Trust Boundary Z):** The point of interaction between the server and the file system where documents are persisted. The attack surface involves disk read/write operations and operating system permissions. This boundary is critical to prevent unauthorized direct access to files (MC-07) and the introduction of malicious files into the server via uploads (MC-08).

3.2 Security Enforcement Points (SEP)

To mitigate the threats identified at the trust boundaries, security responsibilities are distributed across specific architectural enforcement points.

- **SEP.1: Web Entry Point & Request Filtering**
  - **Location:** Interface between the User Browser and the Application Server (Trust Boundary X).
  - **Mechanisms:** Implementation of TLS 1.3 termination, Rate Limiting, and Web Application Firewall (WAF) rules.
  - **Mitigation:** Protects against Man-in-the-Middle (MC-04) and Denial-of-Service (MC-02) attacks before they reach the core application logic.
- **SEP.2: Authentication & Session Middleware**
  - **Location:** The entry layer of the Application Server.
  - **Mechanisms:** Multi-Factor Authentication (MFA) validation, secure session management, and account lockout policies after failed attempts.
  - **Mitigation:** Directly addresses Unauthorized Logon (MC-01) and prevents session hijacking.
- **SEP.3: Logic Layer Authorization (RBAC)**
  - **Location:** Within the application's business logic, prior to resource access.
  - **Mechanisms:** Strict Role-Based Access Control (RBAC) that verifies document ownership or reviewer permissions for every request.
  - **Mitigation:** Mitigates Insecure Direct Object Reference (IDOR / MC-03) and Unauthorized Document Access (MC-07).
- **SEP.4: Data Access Object (DAO) / Database Interface**
  - **Location:** Interface between the Application Server and the PostgreSQL Database (Trust Boundary Y).
  - **Mechanisms:** Enforcement of Prepared Statements and parameterized queries to ensure input is never executed as code.
  - **Mitigation:** Provides a definitive defense against SQL Injection (MC-05).
- **SEP.5: Secure Storage & File Handler**
  - **Location:** Interface between the Application Server and the Document Storage system (Trust Boundary Z).
  - **Mechanisms:** File type white-listing, malware scanning, UUID-based file renaming, and AES-256 encryption for data at rest.
  - **Mitigation:** Prevents Malware Injection (MC-08) and protects against Information Leakage (MC-06) even if physical storage is compromised.

3.3 Architectural Security Principles

The proposed architecture is governed by established security engineering principles to ensure the system is resilient by design. These decisions directly influenced the placement of security enforcement points and the communication protocols between components.

- **Defense in Depth & Zero Trust:** To avoid single points of failure, the system implements redundant layers of security and removes implicit trust within the internal network. Architecturally, we establish an Internal PKI (Public Key Infrastructure) to enforce Mutual Authentication (mTLS) between the Application Server and the Database. Even if an attacker gains access to the internal server network, they cannot communicate with the database without a valid cryptographic identity.

- **Least Privilege:** This principle is applied to both human users and system service accounts. The application server connects to the PostgreSQL database using a dedicated service account with strictly scoped permissions (e.g., SELECT, INSERT, UPDATE), preventing unauthorized schema modifications. On the user level, Role-Based Access Control (RBAC) ensures that users can only interact with documents explicitly associated with their roles.

- **Secure Defaults:** The system is designed to be secure in its initial state without requiring user intervention. By default, all uploaded documents are set to "Private," and visibility to a Reviewer is only granted through explicit sharing. Furthermore, account creation follows a "Disabled-by-Default" policy, requiring administrative activation before access is granted.

- **Separation of Concerns:** Security-critical functions are isolated from business logic to facilitate independent auditing and hardening. The architecture decouples Identity Management from Document Processing. By isolating the authentication middleware from the file handling logic, we ensure that vulnerabilities in functional features do not compromise the global access control system.

- **Fail Securely:** The system must maintain a secure state during unexpected failures or exceptions. In the event of a service disruption or database timeout, the system is designed to default to a "Deny-All" state rather than bypassing security checks. Error handling is configured to suppress internal system details (sanitized error messages), preventing Information Leakage across Trust Boundary X.

4 Traceability Matrix

The traceability matrix bridges the identified threats (Misuse Cases) from Stage 1 to the security requirements, and finally to the architectural mechanisms (Security Enforcement Points) and principles defined in Stage 2. This ensures complete end-to-end coverage of the system's attack surface.

Threat ID (Misuse Case)	**Requirement ID**	**Mechanism (SEP)**	**Architectural Principle**
MC-04 (MitM) & MC-02 (DoS)	SR.4 & SR.2	SEP.1 (WAF, TLS 1.3, Rate Limiting)	Zero Trust
MC-01 (Spoofing)	SR.1 (Auth)	SEP.2 (MFA & Sessions)	Defense in Depth
MC-03 (IDOR) & MC-07 (Access)	SR.3 & SR.7	SEP.3 (RBAC Authorization)	Least Privilege
MC-05 (SQLi) & MC-06 (Leakage)	SR.5 & SR.6	SEP.4 (Prepared Stmt. & mTLS)	Separation of Concerns
MC-08 (Malware Injection)	SR.8 (Integrity)	SEP.5 (Malware Scan & AES-256)	Secure Defaults

Table 6: Security Traceability Matrix mapping threats to architectural defenses.

The logical placement of these Security Enforcement Points and the trust boundaries they defend are visually summarized in the final secure architecture diagram below.

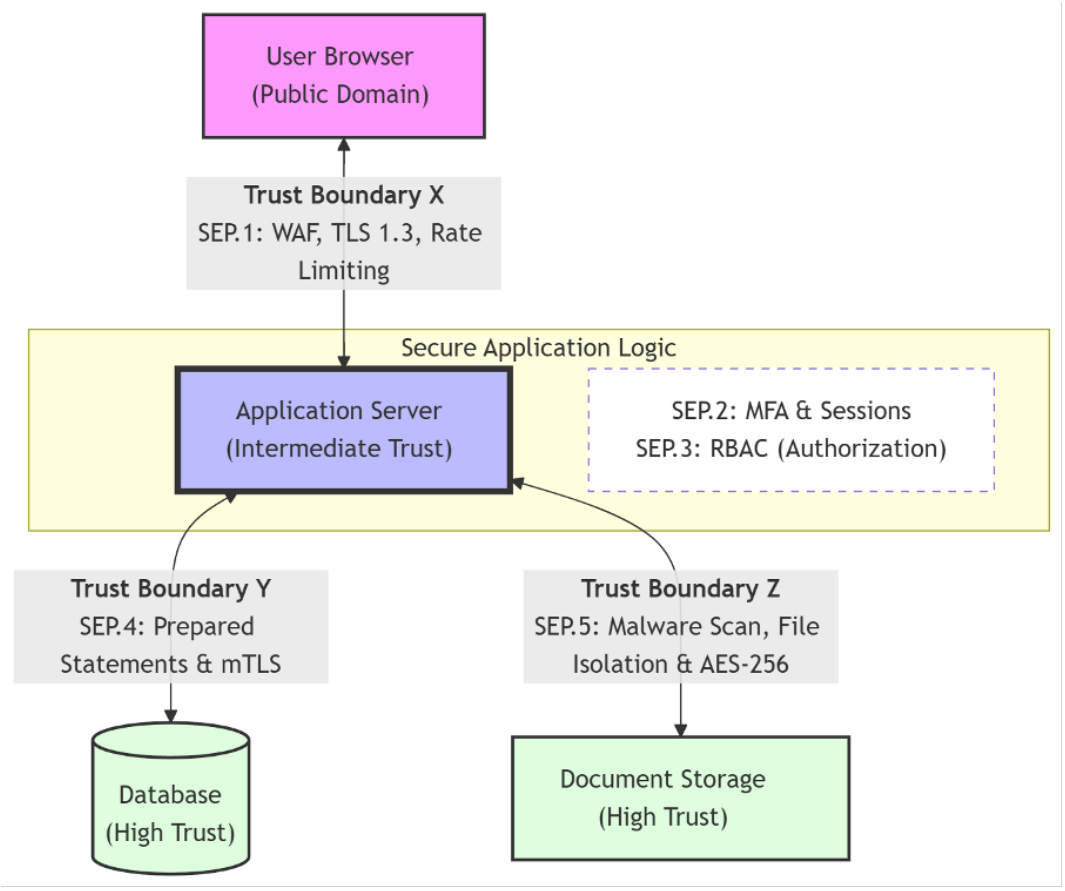

Figure 10: Secure Architecture Diagram illustrating the placement of SEPs and trust boundaries.

References

[1] Mead, N. R., Hough, E. D., & Stehney II, T. R. (2005). *Security Quality Requirements Engineering (SQUARE) Methodology*. Software Engineering Institute, Carnegie Mellon University.

[2] OWASP Foundation. (2021). *OWASP Top 10:2021 - The Most Critical Web Application Security Risks*. Retrieved from `https://owasp.org/www-project-top-ten/`

[3] OPSWAT. (2023). *File Upload Protection Best Practices*. Retrieved from `https://www.opswat.com/blog/file-upload-protection-best-practices`

[4] OWASP Foundation. (2023). *SQL Injection Prevention Cheat Sheet*. Retrieved from `https://cheatsheetseries.owasp.org/cheatsheets/SQL_Injection_Prevention_Cheat_Sheet.html`

[5] Cloudflare. (2024). *How to prevent DDoS attacks*. Retrieved from `https://www.cloudflare.com/learning/ddos/how-to-prevent-ddos-attacks/`

[6] Cymulate. (2023). *Unauthorized Access: Security Controls and Prevention*. Retrieved from `https://cymulate.com/blog/unauthorized-access-security-controls/`

[7] DataStack Hub. (2023). *How to Prevent Data Leakage*. Retrieved from `https://www.datastackhub.com/how-to/how-to-prevent-data-leakage/`

[8] Cyber Army. (2023). *The Complete Guide to Man-in-the-Middle Attacks*. Retrieved from `https://medium.com/@cyberarmy629/the-complete-guide-to-man-in-the-middle-attacks-from-theory-to-practice-57e460a0d6c9`

[9] NIST. (2019). *Guidelines for the Selection, Configuration, and Use of Transport Layer Security (TLS) Implementations* (SP 800-52 Rev. 2). National Institute of Standards and Technology.

A Detailed Misuse Cases and Attack Trees

This appendix contains the exhaustive documentation for each of the eight identified misuse cases, including their specific pre-conditions, post-conditions, and wanted guarantees.

A.1 Misuse Case 01: Unauthorized Logon

Number	MC-01
Name	Unauthorized logon to the server via Spoofing
Scope	User Authentication and Access Control
Priority	☐ Low ☐ Medium ☒ High
Deployment Environment	☐ Intranet ☒ Extranet/Internet
Mis-actors	Unauthorized users / External attackers
Access Right Levels	☒ Low-Level ☒ Medium-Level ☒ High-Level ☒ Sys Admin
Point of Entry	☐ Network ☐ Host ☒ Application
Security Attributes Affected	☒ Confidentiality ☒ Integrity ☐ Availability
Description	An unauthorized user attempts to bypass the login page or use stolen credentials (spoofing) to gain access to the system and sensitive documents.
Sophistication	☒ Low ☐ Medium ☐ High
Pre-conditions	The system provides a login page for basic authentication. Access control lists must be configured for the web service.
Assumptions	The user does not have expressed permission to log on to the server or view specific document assets.
Post-conditions	The unauthorized user successfully logs onto the system; their actions may go undetected if logging is insufficient.
Worst Case Threat	An attacker assumes the identity of an Administrator, gaining full control over user accounts and platform configuration.
Wanted Prevention Guarantee	Enforce strong machine access control list (ACL) security policies and role-based user authentication.
Wanted Detection Guarantee	All logon attempts (failed and successful) are logged and monitored by system administrators.
Wanted Recovery Guarantee	Immediate revocation of unauthorized access rights and session tokens; password reset for compromised accounts.
Potential Mis-actor Profiles	Low to medium skilled individuals using automated tools or social engineering with criminal intent.
Stakeholders and Threats	Stakeholders: loss of reputation and potential legal non-compliance. Clients: loss of data confidentiality and privacy.
Related Threats	Elevation of privilege, disclosure of confidential data, and unauthorized access to administration interface.
Architectural Recommendation	Implement robust role-based authentication control across all endpoints.
Policy Recommendation	Enforce strong password policies and ensure users do not reveal credentials.

A.2 Misuse Case 02: Denial-of-Service

Number	MC-02
Name	Denial-of-Service (DoS) during critical academic periods
Scope	System Availability and Service Continuity
Priority	☐ Low ☐ Medium ☒ High
Deployment Environment	☐ Intranet ☒ Extranet/Internet
Mis-actors	External Attackers / Malicious Users
Access Right Levels	☒ Low-Level ☐ Medium-Level ☐ High-Level ☐ Sys Admin
Point of Entry	☒ Network ☐ Host ☐ Application
Security Attributes Affected	☐ Confidentiality ☐ Integrity ☒ Availability
Description	An attacker floods the Application Server with a multitude of requests or large file uploads, essentially forcing it to slow down or shut down, denying service to legitimate users.
Sophistication	☒ Low ☐ Medium ☐ High
Pre-conditions	The server is accessible via the public internet and lacks rate-limiting or traffic filtering mechanisms.
Assumptions	The attacker intends to disrupt academic operations during peak periods (e.g., submission deadlines).
Post-conditions	The system becomes unresponsive; users are unable to upload or download critical documents.
Worst Case Threat	Prolonged downtime during a critical deadline, leading to loss of academic work and institutional reputation.
Wanted Prevention Guarantee	Implement network-level filtering, rate-limiting, and load balancing to handle traffic spikes.
Wanted Detection Guarantee	Real-time monitoring of network traffic and server resource usage (CPU/RAM/Bandwidth).
Wanted Recovery Guarantee	Automated failover to redundant server lines and traffic scrubbing services.
Potential Mis-actor Profiles	Individuals with low technical skills using publicly available DoS toolkits or disgruntled users.
Stakeholders and Threats	Students and Faculty: inability to meet deadlines; Organization: loss of reputation and operational failure.
Related Threats	Denial of service and resource exhaustion.
Architectural Recommendation	Implement clustering or active/active failover to ensure service sustainability.
Policy Recommendation	Perform routine system and data back-ups to ensure data is not lost during a crash.

A.3 Misuse Case 03: HTTPS Manipulation

Number	MC-03
Name	Manipulation of HTTPS requests (IDOR - Insecure Direct Object Reference)
Scope	Data Privacy and Authorization Logic
Priority	☐ Low ☐ Medium ☒ High
Deployment Environment	☐ Intranet ☒ Extranet/Internet
Mis-actors	Authenticated Malicious Users / Reviewers
Access Right Levels	☒ Low-Level ☒ Medium-Level ☐ High-Level ☐ Sys Admin
Point of Entry	☐ Network ☐ Host ☒ Application (API Endpoints)
Security Attributes Affected	☒ Confidentiality ☒ Integrity ☐ Availability
Description	An authenticated attacker intercepts and modifies the parameters of an HTTPS request (e.g., changing a document ID in the URL or body) to access or download documents belonging to other users.
Sophistication	☐ Low ☒ Medium ☐ High
Pre-conditions	The attacker is logged into the system and the application identifies documents using predictable or sequential identifiers (IDs).
Assumptions	The application server fails to perform a server-side authorization check to verify if the requester owns or is a designated reviewer of the document.
Post-conditions	Sensitive or private information is disclosed to an unauthorized party, violating data privacy requirements.
Worst Case Threat	Mass exfiltration of sensitive documents by iterating through sequential document IDs.
Wanted Prevention Guarantee	Implement indirect object references (maps) or enforce strict server-side access control checks for every object request.
Wanted Detection Guarantee	Log all document access requests and implement alerts for users attempting to access multiple resources that do not belong to them.
Wanted Recovery Guarantee	Audit access logs to identify leaked documents and notify affected owners; invalidate compromised session tokens.
Potential Mis-actor Profiles	Users with basic web debugging knowledge (e.g., using Browser DevTools or Burp Suite) and malicious intent to gather data.
Stakeholders and Threats	Document Owners: loss of privacy; Organization: legal liability under GDPR/CCPA and loss of trust.
Related Threats	Tampering with requests, information disclosure, and unauthorized access to data.
Architectural Recommendation	Implement role-based and attribute-based authentication control at the service level.
Policy Recommendation	Ensure users do not have rights or access levels beyond those prescribed by their job responsibilities.

A.4 Misuse Case 04: Man-in-the-Middle

Number	MC-04
Name	Man-in-the-Middle (MitM) via Network Interception
Scope	Data in Transit Confidentiality and Integrity
Priority	☐ Low ☐ Medium ☒ High
Deployment Environment	☐ Intranet ☒ Extranet/Internet
Mis-actors	Network Eavesdroppers / Malicious Node Operators
Access Right Levels	☐ Low-Level ☐ Medium-Level ☐ High-Level ☐ Sys Admin ☒ External Attacker
Point of Entry	☒ Network ☐ Host ☐ Application
Security Attributes Affected	☒ Confidentiality ☒ Integrity ☐ Availability
Description	An attacker intercepts the communication channel between the User Browser and the Application Server. If TLS/HTTPS is not enforced, the attacker can capture login credentials, session cookies, and sensitive document content in plaintext.
Sophistication	☐ Low ☒ Medium ☐ High
Pre-conditions	The user is accessing the platform over an insecure or public network (e.g., public Wi-Fi), and the system configuration allows non-encrypted connections.
Assumptions	Sensitive data is being transmitted; the attacker has the tools to perform ARP spoofing or DNS poisoning within the network path.
Post-conditions	The attacker gains unauthorized access to private information (Information Disclosure) or alters data packets during transmission (Tampering).
Worst Case Threat	Theft of an Administrator's session cookie, leading to full platform compromise and total data breach.
Wanted Prevention Guarantee	Enforce mandatory TLS/HTTPS for all communications; implement HSTS (HTTP Strict Transport Security) to prevent protocol downgrade attacks.
Wanted Detection Guarantee	Use of Network Intrusion Detection Systems (IDS) and monitoring for anomalous certificate warnings or unauthorized network redirects.
Wanted Recovery Guarantee	Revoke all active session tokens and force a password reset for users whose sessions were intercepted.
Potential Mis-actor Profiles	Technically skilled individuals or groups with the ability to manipulate network traffic for financial or criminal intent.
Stakeholders and Threats	Document Owners: loss of privacy; Organization: loss of reputation and legal liability for data exposure (GDPR).
Related Threats	Information disclosure, tampering with data packets, and session hijacking.
Architectural Recommendation	Secure all network communication channels with industry-standard encryption protocols (TLS 1.3).
Policy Recommendation	Instruct users to never reveal credentials and avoid using untrusted public networks for sensitive document management.

A.5 Misuse Case 05: SQL Injection

Number	MC-05
Name	SQL Injection (SQLi) for Elevation of Privilege
Scope	Database Integrity and Authorization Control
Priority	☐ Low ☐ Medium ☒ High
Deployment Environment	☐ Intranet ☒ Extranet/Internet
Mis-actors	External Attackers / Authenticated Malicious Users
Access Right Levels	☒ Low-Level ☒ Medium-Level ☐ High-Level ☐ Sys Admin
Point of Entry	☐ Network ☐ Host ☒ Application (Input fields/API)
Security Attributes Affected	☒ Confidentiality ☒ Integrity ☒ Availability
Description	An attacker inserts malicious SQL code into application input fields or URL parameters that are not properly sanitized. This allows the execution of unauthorized queries to modify the user's role to "Administrator" in the PostgreSQL database.
Sophistication	☐ Low ☒ Medium ☐ High
Pre-conditions	The application interacts with a database and does not use prepared statements or parameterized queries for user-supplied input.
Assumptions	The attacker has knowledge of common SQL injection patterns and seeks to bypass normal authentication/authorization logic.
Post-conditions	The attacker gains administrative privileges, allowing them to disable accounts, access any document, or delete the entire database.
Worst Case Threat	Total system compromise, including loss of all document data and permanent disruption of service.
Wanted Prevention Guarantee	Use of parameterized queries/prepared statements (ORM); strict input validation and sanitization; enforcement of the "Least Privilege" principle for database connections.
Wanted Detection Guarantee	Real-time monitoring of database logs for anomalous queries and use of Web Application Firewalls (WAF) to detect injection patterns.
Wanted Recovery Guarantee	Restoration of the database from a secure, clean backup; immediate revocation of compromised administrative sessions.
Potential Mis-actor Profiles	Individuals with medium to high technical skills and criminal intent to exfiltrate data or sabotage the platform.
Stakeholders and Threats	Organization: massive data breach and loss of reputation; Clients: total loss of document privacy and integrity.
Related Threats	Elevation of privilege, disclosure of confidential data, and data corruption.
Architectural Recommendation	Implement role-based authentication control and secure data access layers.
Policy Recommendation	Perform routine system and data back-ups; Ensure the web application and DBMS are patched routinely.

A.6 Misuse Case 06: Information Leakage

Number	MC-06
Name	Information Leakage via Insecure Database Storage/Connection
Scope	Data at Rest and Internal Transit Confidentiality
Priority	☐ Low ☐ Medium ☒ High
Deployment Environment	☒ Intranet ☐ Extranet/Internet
Mis-actors	Malicious Insiders / Compromised Application Services
Access Right Levels	☐ Low-Level ☐ Medium-Level ☐ High-Level ☒ Sys Admin ☒ DB Admin
Point of Entry	☐ Network ☒ Host ☒ Database
Security Attributes Affected	☒ Confidentiality ☐ Integrity ☐ Availability
Description	An attacker gains access to user metadata or sensitive document information because the database lacks encryption at rest or the connection between the application and the database is unencrypted. This allows for the mass extraction of records if the host is compromised.
Sophistication	☐ Low ☒ Medium ☐ High
Pre-conditions	The database (PostgreSQL) is running with default configurations and does not enforce SSL/TLS for internal connections.
Assumptions	The attacker has gained a foothold in the internal network or the host machine and seeks to exfiltrate the document management platform's entire dataset.
Post-conditions	Large volumes of sensitive user data and document metadata are disclosed, leading to a massive privacy breach.
Worst Case Threat	Exposure of all stored digital documents, including those with private information, resulting in severe legal penalties and total loss of user trust.
Wanted Prevention Guarantee	Implement Transparent Data Encryption (TDE) for the database and enforce encrypted (SSL) connections for all database queries.
Wanted Detection Guarantee	Audit logging of all administrative database queries and monitoring for large-scale data export operations.
Wanted Recovery Guarantee	Immediate rotation of database credentials and encryption keys; forensic analysis to determine the extent of the data exfiltration.
Potential Mis-actor Profiles	Skilled insiders or external attackers who have already bypassed perimeter defenses and are targeting the core data store.
Stakeholders and Threats	Stakeholders: loss of reputation and legal non-compliance with GDPR; Document Owners: total loss of privacy.
Related Threats	Information disclosure, unauthorized access to configuration stores, and retrieval of plaintext secrets.
Architectural Recommendation	Store audit information in a separate location from the servers; Enforce authentication and encryption on all data access connections.
Policy Recommendation	Perform routine system and data back-up; Periodically review user activities and database access logs.

A.7 Misuse Case 07: Unauthorized Document Access

Number	MC-07
Name	Unauthorized Document Access via Insecure Storage
Scope	Protection of Data at Rest (Document Storage)
Priority	☐ Low ☐ Medium ☒ High
Deployment Environment	☒ Intranet ☐ Extranet/Internet
Mis-actors	Malicious Insiders / Attackers with Host Access
Access Right Levels	☐ Low-Level ☐ Medium-Level ☐ High-Level ☒ Sys Admin ☒ Other Network User
Point of Entry	☐ Network ☒ Host ☒ Storage System
Security Attributes Affected	☒ Confidentiality ☐ Integrity ☐ Availability
Description	An attacker gains direct access to the document storage directory or volume. If the documents are stored in plaintext and the storage connection is not encrypted, the attacker can bypass application-level permissions to read sensitive files.
Sophistication	☐ Low ☒ Medium ☐ High
Pre-conditions	Documents are stored on the disk without file-level encryption or volume encryption; the server host has inadequate directory permissions.
Assumptions	The attacker has achieved a foothold on the server host or has physical/network access to the storage infrastructure.
Post-conditions	Sensitive digital documents are exposed to unauthorized individuals, bypassing the application's Access Control List (ACL).
Worst Case Threat	Mass disclosure of all private user documents, leading to a total loss of privacy and severe legal consequences under GDPR.
Wanted Prevention Guarantee	Implement encryption at rest for all files in the Document Storage; enforce strict OS-level permissions (Least Privilege) for the service account.
Wanted Detection Guarantee	Enable File Integrity Monitoring (FIM) and log all direct file system access attempts to the document repository.
Wanted Recovery Guarantee	Perform a forensic audit to identify accessed files; rotate encryption keys and re-secure the host environment.
Potential Mis-actor Profiles	High-level users or external attackers with host-level access and high criminal intent to exfiltrate private assets.
Stakeholders and Threats	Document Owners: loss of private information; Organization: massive loss of reputation and legal non-compliance.
Related Threats	Information disclosure, unauthorized access to configuration stores, and physical/logical theft of assets.
Architectural Recommendation	Encrypt all sensitive data at rest and ensure secure data access connections.
Policy Recommendation	Ensure password protection or encryption for all shared/stored documents; Restrict access levels to minimum job requirements.

A.8 Misuse Case 08: Malware Injection

Number	MC-08
Name	Malware Injection via Document Upload
Scope	Software Integrity and Workstation Security
Priority	☐ Low ☐ Medium ☒ High
Deployment Environment	☐ Intranet ☒ Extranet/Internet
Mis-actors	Authenticated Malicious Users / External Attackers with stolen credentials
Access Right Levels	☒ Low-Level ☐ Medium-Level ☐ High-Level ☐ Sys Admin
Point of Entry	☐ Network ☐ Host ☒ Application (Upload Functionality)
Security Attributes Affected	☐ Confidentiality ☒ Integrity ☒ Availability
Description	An attacker uploads a malicious file (e.g., an executable masquerading as a PDF or a script-embedded document) to the platform. When a Reviewer or Administrator downloads and opens the file, their workstation is compromised.
Sophistication	☐ Low ☒ Medium ☐ High
Pre-conditions	The application allows document uploads without verifying file content, signatures, or performing virus scanning.
Assumptions	Legitimate privileged users trust the files stored on the platform and will open them on their local machines.
Post-conditions	Malicious code is executed on a Reviewer's or Administrator's workstation, potentially leading to session theft or lateral movement.
Worst Case Threat	Full compromise of an Administrator's workstation, allowing the attacker to gain total control over the platform and its database.
Wanted Prevention Guarantee	Implement strict file-type whitelisting, deep packet inspection of uploads, and mandatory server-side virus/malware scanning.
Wanted Detection Guarantee	Real-time alerts from an integrated anti-malware engine and logging of all file upload/download activities for audit.
Wanted Recovery Guarantee	Immediate isolation and deletion of the malicious file; incident response protocol to sanitize affected workstations.
Potential Mis-actor Profiles	Technically competent individuals seeking to escalate privileges or perform industrial espionage/sabotage.
Stakeholders and Threats	Reviewers and Admins: compromise of personal/work hardware; Organization: loss of reputation and operational integrity.
Related Threats	Tampering with system data, execution of malicious code, and elevation of privilege.
Architectural Recommendation	(AR-19) Implement role-based authentication control and store audit info in a separate, secure location.
Policy Recommendation	Ensure operating systems are patched routinely and periodically review user activities.